

# Zanzirangi Security Checklist

|                 |                                                                                                                  |
|-----------------|------------------------------------------------------------------------------------------------------------------|
| Audit date      | 2026-10-01                                                                                                       |
| Revision        | main @ 2379f82 + uncommitted working tree                                                                        |
| Method          | <b>Static, code-level review only.</b> No exploitation, scanning of live hosts, or access to production systems. |
| Reference       | OWASP Top 10 (2021) categories noted as A01–A10; OWASP ASVS principles                                           |
| Confidentiality | Internal. No secret values are reproduced here.                                                                  |

Severity scale: **CRITICAL · HIGH · MEDIUM · LOW · INFORMATIONAL**

## 1. Findings

| ID   | Severity | OWASP     | Area                   | Finding                                                                                                                                                                                                                                                            | Evidence                                                                                                                                                                                                                                       | Recommendation                                                                                                                        |
|------|----------|-----------|------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| S-01 | HIGH     | A05 / A02 | Secrets in docs        | Committed documentation contains the production DB username and DB name, the remote MySQL host name, the developer's public IP and the DB server IP, the phpMyAdmin URL, the hosting account home path, and hints about the DB password (length / last character). | HOSTINGER_MYSQL_FORENSIC_VERIFICATION.md , docs/HOSTINGER_PRODUCTION_DEPLOYMENT*.md , docs/HOSTINGER_REMOTE_MYSQL_DIAGNOSTIC.md , docs/MYSQL_PROJECT_CREDENTIAL_FORENSIC_AUDIT.md , root HOSTINGER_DEPLOYMENT.md (≈120 matches across 18 docs) | Redact; purge from git history if the repository is or may become public; rotate the DB password; disable or IP-restrict Remote MySQL |
| S-02 | HIGH     | A05 / A04 | Environment separation | Local .env / .env.local point to a non-local MySQL host. Test suites ( test:suites , smoke-test , persistence tests) perform CRUD writes, and scripts/restore-exact-baseline.ts disables FK checks and <b>TRUNCATEs every table.</b>                               | .env (key names only inspected); scripts/restore-exact-baseline.ts:53                                                                                                                                                                          | Dedicated local/test DB; production credentials only in hPanel; scripts must refuse a production host unless explicitly confirmed     |
| S-03 | HIGH     | A07 / A09 | Token exposure         | scripts/print-superadmin-token.ts (untracked) signs and prints a valid superadmin JWT (7-day default lifetime) plus user details to stdout.                                                                                                                        | scripts/print-superadmin-token.ts:9-10                                                                                                                                                                                                         | Delete the script; if needed for tests, mint short-lived tokens against a test DB only                                                |
| S-04 | MEDIUM   | A02 / A04 | Sensitive local files  | Snapshot files in backups/ (and server/data/*.backup ) contain full table dumps including users password hashes. They are gitignored but stored unencrypted on the developer machine.                                                                              | scripts/create-exact-baseline-snapshot.ts , backups/ (3 files)                                                                                                                                                                                 | Encrypt or delete after use; never include in zips/shares                                                                             |

| ID   | Severity | OWASP | Area                     | Finding                                                                                                                                                                                                                                    | Evidence                                                               | Recommendation                                                                                  |
|------|----------|-------|--------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| S-05 | MEDIUM   | A07   | Session token storage    | Admin JWT is returned in the response body and stored in <code>localStorage</code> ; any XSS would allow token theft (7-day validity). The <code>httpOnly</code> cookie is also set but the client uses the Bearer header.                 | <code>server/api.ts:168-186; src/services/authApi.ts:23</code>         | Use <code>httpOnly</code> cookie only + CSRF token; shorten expiry; add refresh/idle timeout    |
| S-06 | MEDIUM   | A05   | Security headers (HTML)  | No Content-Security-Policy, X-Frame-Options or HSTS on HTML/static responses; headers are only applied to <code>/api/*</code> and <code>/uploads</code> .                                                                                  | <code>server/index.ts:58-95</code> vs <code>server/api.ts:53-65</code> | Add headers (e.g. <code>helmet</code> ) for all responses with a CSP allowing Google Fonts/Maps |
| S-07 | MEDIUM   | A04   | Abuse / rate limiting    | Public support endpoints ( <code>POST /api/support/conversation</code> , <code>/messages</code> , <code>/poll</code> ) have no rate limiting or size limits on <code>metadata</code> ; anyone can create unlimited conversations/messages. | <code>server/supportApiRoutes.ts:32-257</code>                         | Per-IP rate limit, message length cap, metadata schema/size limit, optional bot challenge       |
| S-08 | MEDIUM   | A02   | Transport (DB)           | MySQL pool has no TLS option; scripts and local dev connect to a remote MySQL host over an unencrypted connection. Production via <code>127.0.0.1</code> is unaffected.                                                                    | <code>server/database/connection.ts:43-55</code>                       | Enable TLS for any remote connection or stop using remote access                                |
| S-09 | MEDIUM   | A05   | Configuration            | If <code>CORS_ORIGIN</code> is set to <code>*</code> , the API maps it to <code>origin: true with credentials: true</code> , reflecting any origin with credentials.                                                                       | <code>server/config/env.ts:37-43; server/api.ts:68-69</code>           | Reject <code>*</code> in production validation                                                  |
| S-10 | LOW      | A01   | Authorisation            | <code>POST /api/admin/media/upload</code> requires authentication but not the <code>media</code> permission.                                                                                                                               | <code>server/api.ts:870</code>                                         | Add <code>requireAnyPermission([...content modules, 'media'])</code> or document as intended    |
| S-11 | LOW      | A01   | Authorisation (UI)       | Admin pages render for any logged-in admin via direct URL; only navigation is filtered. Server enforces data access (403).                                                                                                                 | <code>src/admin/AdminLayout.tsx:81-92; src/App.tsx:518-563</code>      | Gate page rendering client-side for UX consistency                                              |
| S-12 | LOW      | A03   | Input validation         | Most admin content writes accept free-form JSON bodies with minimal schema validation (users and contact endpoints are the exceptions).                                                                                                    | e.g. <code>server/api.ts:478-496, 919-926</code>                       | Add schema validation (e.g. <code>zod</code> ) per endpoint                                     |
| S-13 | LOW      | A09   | Error leakage            | Some admin endpoints return raw <code>err.message</code> (users, contact-info, upload); public <code>/api/health</code> returns the DB error message when degraded.                                                                        | <code>server/api.ts:108, 536, 905, 1388, 1499, 1606</code>             | Return generic messages; log details server-side                                                |
| S-14 | LOW      | A07   | Authentication hardening | No MFA, no account lockout (IP rate limit only), no self-service password reset, 7-day sessions.                                                                                                                                           | <code>server/auth.ts</code>                                            | MFA for superadmin; shorter sessions                                                            |

| ID   | Severity | OWASP | Area                  | Finding                                                                                                                                    | Evidence                                                           | Recommendation                                     |
|------|----------|-------|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------|----------------------------------------------------|
| S-15 | LOW      | A08   | Migrations            | Manual migrations with naive ; splitting; schema_migrations not consulted; MariaDB-only syntax in 003.                                     | scripts/run-*-migration.ts; 003_full_cms_coverage.sql:6-8          | Versioned migration runner                         |
| S-16 | LOW      | A05   | Legacy deploy targets | GitHub Pages workflow publishes on every push; repository visibility unknown (Pages on free plans implies public).                         | .github/workflows/deploy.yml                                       | Disable; confirm repository is private             |
| S-17 | INFO     | A03   | XSS sinks             | Only one dangerouslySetInnerHTML (JSON-LD breadcrumbs; JSON.stringify of route labels). React escapes all other output.                    | src/components/Breadcrumbs.tsx:50                                  | Escape < in serialized JSON-LD as defence in depth |
| S-18 | INFO     | A03   | SQL injection         | All queries use placeholders; the only interpolations are hard-coded table names or placeholder lists.                                     | server/database/mysqlAdapter.ts, supportRepository.ts              | None                                               |
| S-19 | INFO     | A06   | Dependencies          | npm audit reports 0 vulnerabilities (2026-10-01). @google/genai is unused.                                                                 | —                                                                  | Remove unused dependency; schedule monthly audits  |
| S-20 | INFO     | A09   | Logging               | Logs do not include passwords or JWT secrets; scripts log DB user/host/DB name. Audit log records email + IP for logins and admin actions. | server/database/connection.ts; scripts/migrate-json-to-mysql.ts:59 | Retain; define log retention                       |

No CRITICAL findings were identified at code level.

## 2. Control Checklist

| Control                                        | Status                                                                                                      | Evidence                               |
|------------------------------------------------|-------------------------------------------------------------------------------------------------------------|----------------------------------------|
| Passwords hashed with adaptive algorithm       | ✅ bcrypt, cost 12                                                                                           | server/api.ts:1351, server/auth.ts:235 |
| Password length policy                         | ✅ 8–72 chars (admin create/reset)                                                                           | server/api.ts:1326                     |
| User enumeration protection                    | ✅ dummy-hash compare; generic error                                                                         | server/auth.ts:52-53, 233-238          |
| Login brute-force protection                   | ✅ 10 / 15 min / IP (production only)                                                                        | server/api.ts:78-88                    |
| Session revocation                             | ✅ token_version on logout/disable/reset/role change                                                         | server/auth.ts:131-138                 |
| Session cookie flags                           | ✅ httpOnly, SameSite=Lax, Secure (prod)                                                                     | server/api.ts:168-173                  |
| Token storage in browser                       | ❌ localStorage                                                                                              | S-05                                   |
| CSRF                                           | ⚠️ Bearer-header auth is CSRF-immune; cookie auth relies on SameSite=Lax + JSON content type; no CSRF token | server/auth.ts:86-92                   |
| Server-side authorisation on every admin route | ✅ (one LOW exception, S-10)                                                                                 | server/api.ts                          |
| Least privilege / module permissions           | ✅ 17 module keys, allow-listed                                                                              | server/auth.ts:25-50                   |

| Control                                      | Status                                                                                                           | Evidence                                                         |
|----------------------------------------------|------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|
| Superadmin safeguards                        | ✅ self-demotion and last-superadmin protection; 6 active admin cap                                               | server/api.ts:1448-1475                                          |
| Secrets via environment only                 | ✅ in code; ❌ identifiers in docs (S-01)                                                                          | server/config/env.ts                                             |
| Production config fail-fast                  | ✅ provider, JWT strength, DB vars                                                                                | server/config/env.ts:90-117                                      |
| .env excluded from git and deploy zip        | ✅                                                                                                                | .gitignore:7-8; scripts/package-hostinger-zip.mjs:80-124         |
| Input validation                             | ⚠️ partial (S-12)                                                                                                | —                                                                |
| SQL injection                                | ✅ parameterised                                                                                                  | S-18                                                             |
| XSS                                          | ✅ React escaping; ⚠️ no CSP                                                                                      | S-06, S-17                                                       |
| File upload safety                           | ✅ allow-list, MIME + magic bytes, size cap, sanitized names, path containment, SVG blocked, sandbox CSP on serve | server/storage/LocalMediaStorage.ts:9-123; server/index.ts:33-41 |
| CORS                                         | ✅ single origin in prod; ⚠️ * misconfiguration risk (S-09)                                                       | server/api.ts:68-69                                              |
| Rate limiting (non-login)                    | ❌                                                                                                                | S-07                                                             |
| Security headers (API)                       | ✅ nosniff, XFO, Referrer-Policy, Permissions-Policy, HSTS (prod), no-store                                       | server/api.ts:53-65                                              |
| Security headers (HTML)                      | ❌                                                                                                                | S-06                                                             |
| HTTPS enforcement                            | ⚠️ HSTS on API only; TLS/redirect at host NOT VERIFIED                                                           | —                                                                |
| Error handling hides internals in production | ✅ mostly; ⚠️ S-13                                                                                                | server/api.ts:1645-1659                                          |
| Audit trail                                  | ✅ logins, failed logins, user admin, content changes                                                             | audit_logs                                                       |
| Dependency scanning                          | ⚠️ manual only ( npm audit clean)                                                                                | —                                                                |
| DB transport encryption                      | ❌ for remote connections (S-08)                                                                                  | —                                                                |
| Backups / recoverability                     | ❌ not implemented / not verified                                                                                 | Brief §15                                                        |
| Security monitoring / alerting               | ❌                                                                                                                | Brief §16                                                        |

### 3. Remediation Order

1. **Immediately:** S-01 (redact + rotate DB password + restrict Remote MySQL), S-02 (separate DB), S-03 (delete token script), S-04 (dispose of snapshots).
2. **Before launch:** S-07, S-09, confirm S-16 (repository private, Pages disabled).
3. **Next sprint:** S-05, S-06, S-08, S-10, S-13.
4. **Backlog:** S-11, S-12, S-14, S-15, S-17, S-19.

### 4. Items Requiring External Verification

- TLS certificate validity, HTTP→HTTPS redirect, HSTS at the edge.
- Hostinger firewall / Remote MySQL allow-list.
- Repository visibility (public/private) and GitHub access list.
- Who holds hPanel, domain registrar and GitHub credentials; whether MFA is enabled on those accounts.
- Hostinger backup configuration and retention.